



SUBJECT	VULNERABILITY ANALYSIS
CODE	IKB21004 & IKB21403
TASK	FILE ANALYSIS – SCANNING RESULT

Question 1: Analyse packet1.pcap and find the flag.

Protocol: ICMP (1)
Header Checksum: 0x9e2 (validation disabled)
[Header checksum status: Unverified]
Source Address: 172.24.20.31
Destination Address: 171.64.20.62
[Stream index: 0]
Internet Control Message Protocol
Type: Echo (ping) reply (0)
Code: 0
Checksum: 0x1ca8 (correct)
[Checksum Status: Good]
Identifier (BE): 1 (0x0001)
Identifier (LE): 256 (0x0100)
Sequence Number (BE): 0 (0x0000)
Sequence Number (LE): 0 (0x0000)
Data (28 bytes)
Data: 553156445655979444497a65324670583267a58324e7662327839
[Length: 28]
Data (data.data), 28 bytes

0000 00 0c 29 58 4f 6e b4 0c 25 ea 40 10 08 00 45 00 ...XOn...%@...E:
0010 00 38 02 2d 00 00 3f 01 f9 e2 ac 18 14 1f ab 40 ...8...?.....@
0020 14 3e 00 00 1c a8 00 01 00 00 55 31 56 44 56 45 ...>.....U1VDVE
0030 59 79 4d 44 49 7a 65 32 46 70 58 32 6c 7a 58 32 YyMDIze2FpX2lzX2
0040 4e 76 62 32 78 39 Nvb2x9

```
(kali@kali)-[~]  
$ echo "U1VDVEYyMDIze2FpX2lzX2Nvb2x9" | base64 -d  
SUCTF2023{ai_is_cool}
```

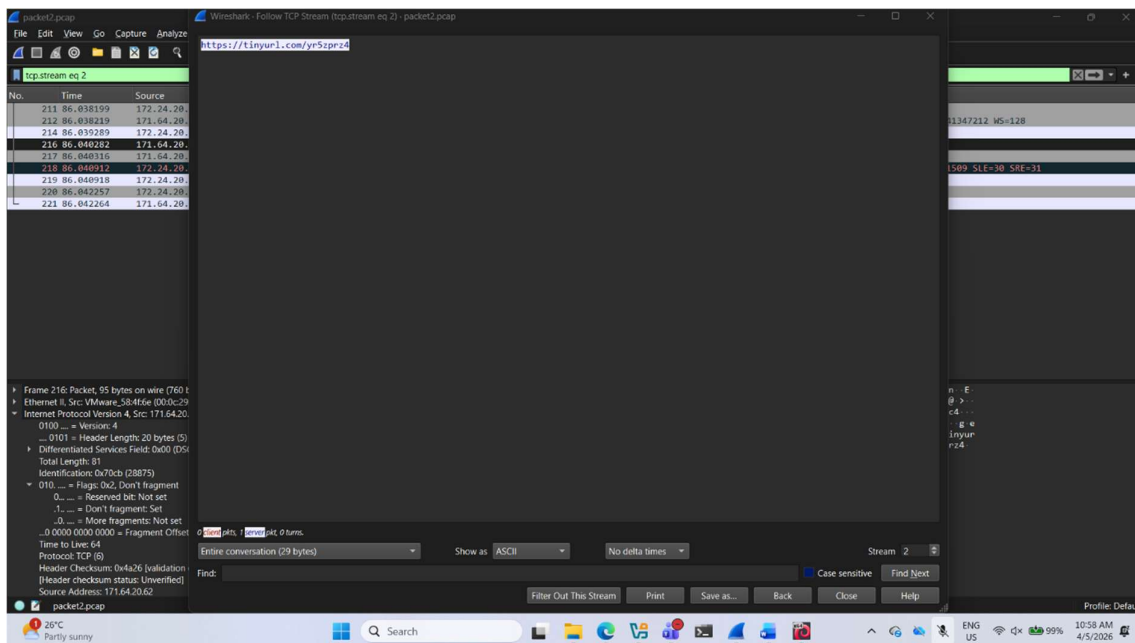
Packet 37 stands out because its length (70 bytes) differs from all other packets (98 bytes). Inspecting the ICMP data payload in the hex dump reveals a Base64-encoded string: U1VDVEYyMDIze2FpX2lzX2Nvb2x9. Decoding it gives the flag: **SUCTF2023{ai_is_cool}**

Question 2: Analyse packet2.pcap and find the flag.

Upon opening packet2.pcap in Wireshark, 794 packets were observed containing a mix of ICMP, TCP and FTP traffic. Filtering by `tcp.port == 4444` revealed a TCP conversation on port 4444, which is commonly associated with reverse shells. Following the TCP stream showed a plaintext chat referencing the movie WarGames, with messages discussing how tic-tac-toe is a pointless game because it always ends in a tie.

Filtering by **ftp** revealed an FTP session where a user logged in anonymously and downloaded a file called `global_thermonuclear_war.gamerules.txt`. Changing the filter to `ftp-data` and following the TCP stream showed the file content, which contained a URL:

<https://tinyurl.com/yr5zpr4z>



Opening the URL in a browser led to a Google Doc titled “Club Tux” containing cipher symbols. The document title hints at the Club Penguin Tic-Tac-Toe cipher, which is a variant of the Pigpen cipher. Decoding the symbols reveals the flag for this challenge.



Question 3: Interpret an Nmap Output

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 5.3p1
80/tcp    open  http     Apache 2.2.8
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Professional 7601 Service Pack 1
```

Questions:

1. What can an attacker do with each port?
 - Port 21 (FTP): Try anonymous login, brute force credentials, intercept passwords (FTP sends them in plaintext), upload malicious files.
 - Port 22 (SSH): Brute force passwords, exploit old OpenSSH vulnerabilities, use as persistent access once credentials are found.
 - Port 80 (HTTP): Scan for web app vulnerabilities (SQLi, XSS), enumerate directories, exploit outdated Apache bugs.
 - Port 139/445 (SMB): Enumerate users, shares, and groups. Attempt EternalBlue exploit, access shared files, pass-the-hash attacks.
2. What vulnerabilities are likely present based on the version?
 - vsftpd 2.3.4 → has a famous backdoor (CVE-2011-2523). A :) smiley in the username opens a shell on port 6200.
 - OpenSSH 5.3p1 → outdated, vulnerable to user enumeration.
 - Apache 2.2.8 → end-of-life, multiple known CVEs (directory traversal, DoS).
 - Windows 7 SP1 (SMB) → vulnerable to EternalBlue (MS17-010 / CVE-2017-0144), allows remote code execution.
3. Which one is the highest risk and why?
 - Port 21 — vsftpd 2.3.4 is the highest risk because the backdoor gives instant remote shell access without any credentials. It's trivially exploitable using Metasploit (exploit/unix/ftp/vsftpd_234_backdoor).
4. What attack path can be built from this?
 - Exploit vsftpd 2.3.4 backdoor → get shell on port 6200
 - Enumerate system, find credentials/hashes
 - Use EternalBlue on port 445 for another access path
 - Check Apache (port 80) for web app vulnerabilities
 - Use discovered credentials on SSH (port 22) for persistent access
 - Pivot through SMB shares for lateral movement

5. What should be the remediation?

- Update vsftpd to a patched version (or use SFTP instead)
- Upgrade OpenSSH to latest version
- Upgrade Apache to 2.4.x (current supported version)
- Upgrade Windows 7 to Windows 10/11 (apply MS17-010 patch)
- Disable unnecessary services
- Implement firewall rules and strong password policies

Question 4: Identify the OS (OS Fingerprinting) - TTL

Image 1

```

[sk@ostechnix ~]$ ping -c5 localhost
PING localhost(localhost (:::1)) 56 data bytes
64 bytes from localhost (:::1): icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from localhost (:::1): icmp_seq=2 ttl=64 time=0.057 ms
64 bytes from localhost (:::1): icmp_seq=3 ttl=64 time=0.070 ms
64 bytes from localhost (:::1): icmp_seq=4 ttl=64 time=0.067 ms
64 bytes from localhost (:::1): icmp_seq=5 ttl=64 time=0.056 ms

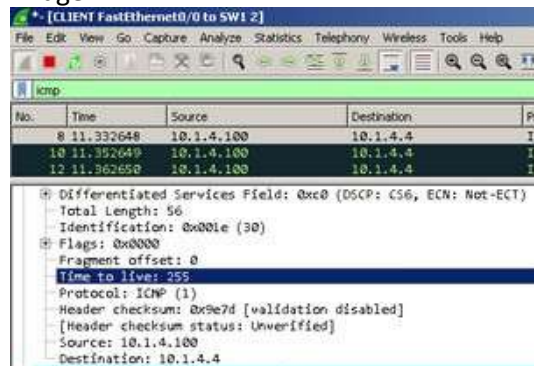
--- localhost ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4096ms
rtt min/avg/max/mdev = 0.056/0.062/0.070/0.005 ms

```

Answer:

- The TTL value observed is 64, which indicates a Linux/Unix operating system. Linux systems use a default TTL of 64 when sending packets.

Image 2



Answer:

- The TTL value observed is 255, which indicates a network device such as a router or switch, likely running Cisco IOS. Network devices typically use a default TTL of 255.

Image 3:

```

64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms

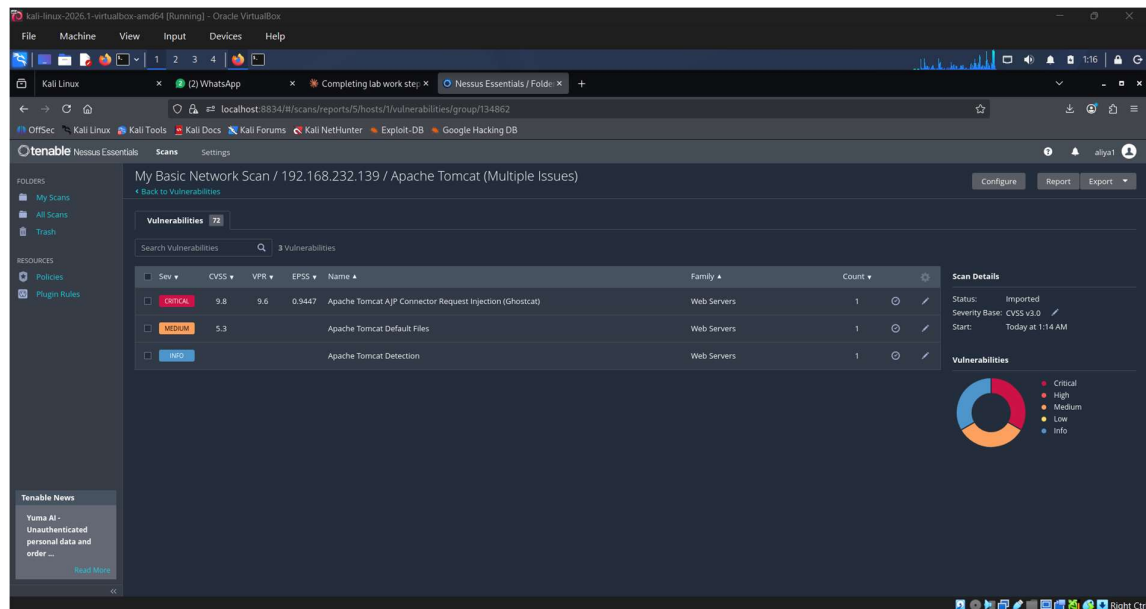
```

Answer:

- The TTL value observed is 128, which indicates a Windows operating system. Windows systems use a default TTL of 128 when sending packets.

Question 5: Analyse the Nessus file

Upload to your nessus (Network_Scan.nessus) and analyse the files. Focus on critical or high findings that was identifies in analysis named "Ghostcat".



1. What is the affected Port number?
 - **Port: 8009**
2. What is the affected protocol?
 - **Protocol: TCP**
3. What is the CVSS Score of vulnerability found?
 - **CVSS Score: 9.8**
4. Can you find any exploit related to this vulnerability?
 - **Exploit available: Yes, Metasploit has a module for this vulnerability, and public Python PoC scripts are available on GitHub.**
5. Find CVE for this vulnerability.
 - **CVE: CVE-2020-1938**